

创意银航（山东）技术有限公司

信息安全管理流程

编制机构： 运维部

编制时间： 2025 年 01 月6 日

版本名称：CYYH-ITSS-15-08

文件起草人：张延山

文件审核人：姜晓建

文件审批人：谢晓彤

生效时间： 2025 年 01 月 8 日

文件修改记录

文件版本	修订内容	修改人	审核人	生效日期
V1.0	初始版本，文档建立	张延山	姜晓建	2022.11.8
V1.1	部门调整	张延山	姜晓建	2025.1.8

目录

1. 文档简介	4
2. 适用范围	4
3. 流程目标	4
4. 流程策略	4
4.1. 信息安全方针	4
4.2. 安全资源管理策略	4
5. 流程角色与职责	5
5.1. 信息安全员/项目经理	5
5.2. 服务台专员	5
5.3. 运维工程师	5
6. 流程描述	5
6.2. 流程说明	6
7. 风险识别评估	7
8. 信息安全事件处理流程	8
8.1. 信息安全事件的定义	8
8.2. 信息安全事件的发现和报告	8
8.3. 信息安全事件的处理和解决	8
8.4. 信息安全事件的关闭	8
9. 安全措施和安全规范	8
10. 公司网络管理员安全管理策略	9
11. 密码与权限管理策略	9
12. 公司信息安全管理策略	10
13. 运维项目现场/客户的信息安全管理策略	10
14. 流程指标	11
15. 流程持续改进	11

1. 文档简介

本文档定义了信息安全管理流程，主要包括：

- 流程目标，描述信息安全管理流程所要达到的目标；
- 流程描述，包括流程图、活动描述及输入输出；
- 流程角色和职责，描述流程中主要的角色，以及角色所担负的职责和需具备的技能要求；
- 流程指标，定义了衡量流程管理绩效的指标；
- 流程持续改进，定义流程回顾和改进方法；

2. 适用范围

信息安全管理流程适用的范围主要是运维服务，服务模式包括驻场式及非驻场式。业务线条包括：

- 硬件运维服务业务线；
- 软件运维服务业务线。

3. 流程目标

本流程目的在于规范服务管理和提供人员在提供服务流程中应遵循和执行的相关活动，保证信息安全管理目标的实现，满足 SLA 中的信息安全性需求以及合同、法律和外部政策等的要求。

- 在所有的服务活动中有效地管理信息安全；
- 使用标准的方法和步骤有效而迅速的处理各种与信息安全相关的问题，识别并跟踪组织内任何信息安全授权访问；
- 执行操作级别协议和基础合同范围内的信息安全需求；
- 满足运维服务中的客户安全性需求、自身的信息安全要求以及合同、法律和外部政策等外部要求。

4. 流程策略

4.1. 信息安全方针

公司信息安全方针为：预防为主、全面管理、保障运营和持续优化。

4.2. 安全资源管理策略

- 提供建立、实施、运营和维护安全管理体系所需的资源，确保信息安

全管理能够支持业务需求；

- 应按法律法规要求以及合同安全职责规定提供资源；
- 应提供资源进行正确的应用软件操作控制措施满足安全需求；
- 在必要时应提供资源实施回顾，并针对回顾结果采取必要的措施；
- 在必要时应提供资源以提高信息安全管理体的效率。

5. 流程角色与职责

5.1. 信息安全员/项目经理

- 负责信息安全管理流程的设计、评估和完善；
- 负责确定客户和业务对服务信息安全的详细需求；
- 根据组织安全需求，开发与维护安全计划，制定信息安全管理规范；
- 负责调配相关人员实施信息安全管理流程以及相关的方法和技术；
- 保证服务信息安全管理流程以及相关的方法和技术被定期回顾和评审；
- 识别信息安全管理过程中存在的问题并提出改进措施。

5.2. 服务台专员

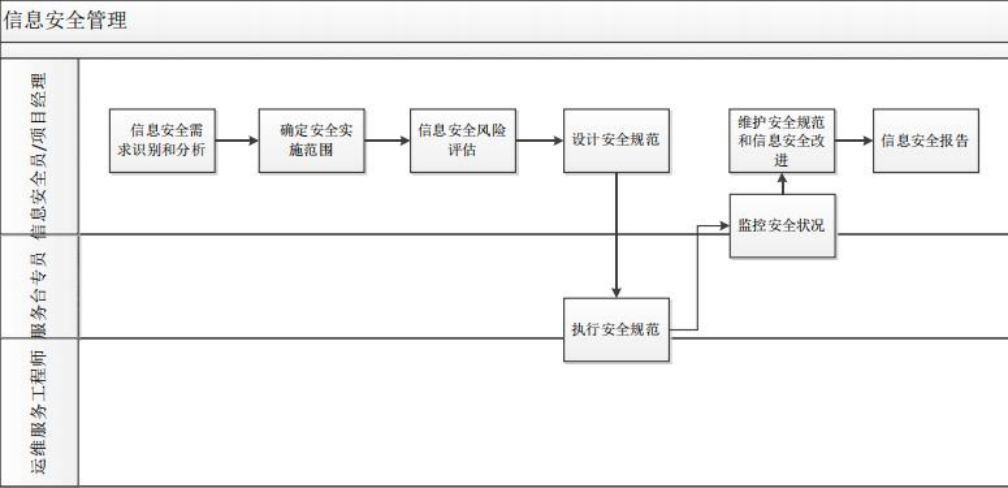
- 协助信息安全员/项目经理进行信息安全规范执行的监督、管控工作；
- 参加信息安全管理培训；
- 在日常服务工作，严格执行相应信息安全管理规范和要求。

5.3. 运维工程师

- 参加信息安全管理培训；
- 在日常服务工作，严格执行相应信息安全管理规范和要求。

6. 流程描述

6.1. 流程图



6.2. 流程说明

活动	描述	责任人	输入	输出
信息安全需求识别和分析	识别客户对信息安全的需求和目标，进行信息安全需求分析。信息安全需求要求的来源主要包括： 1. 服务合同或 SLA 相关条款中约定； 2. 法律法规的要求； 3. 客户业务特点或所在行业业务特性所确定的安全要求； 4. 公司内部的安全要求。	项目经理		
确定安全实施范围	根据安全需求确定安全实施范围。安全实施范围包括列为相应安全等级的数据、人员、终端设备等。	运维部经理		
信息安全风险评估	由涉及部门及客户负责人根据资产识别情况制定风险评估方法，通过识别信息资产、风险等级评估认知本公司的安全风险，在考虑控制成本与风险平衡的前提下选择合适控制目标和控制方式将安全风险控制在可接受的水平，并提交《风险评估报告》。	项目经理		风险评估

设计安全规范	根据《风险评估报告》，信息安全管理员制定和编写《信息安全管理规范》。并根据信息安全规范制定信息安全策略、针对个人的保密协议、岗位职责说明。	项目经理		信息安全规范
执行安全规范	在设计好安全规范后，进行相应培训，在日常服务工作须按照安全规范来实施安全管理。	服务台专员/系统工程师	信息安全规范	信息安全培训记录
监控安全状况	对安全规范实施进行监控，在工作周报、服务月报中体现，制定《信	项目经理/	信息安全规范	信息安全事件
	息安全事件记录》。	服务台专员		记录
维护安全规范和信息安全改进	信息安全实施过程中，针对存在问题的进行相应的改进计划和改进措施。	项目经理	信息安全事件记录	改进计划
信息安全报告	对信息安全的实施状况及日常发生的安全事件等需编写安全报告。	项目经理		信息安全报告

7. 风险识别评估

运维部经理应组织人员主动检查客户/公司在信息技术的安全方面所面临的风险。

针对客户明确运维对象的信息安全属于客户责任范围的项目，遵循以下原则进行列举检查表形式的风险评估：

- 1) 主动识别来自法律法规、行业规定、客户要求（包括服务级别协议）的安全需求，制定安全措施和安全规范满足安全需求；
- 2) 制定措施确保服务相关人员遵守客户现场的安全制度；
- 3) 应主动识别服务相关人员可能接触到的客户机密和敏感信息，制定措施确保服务相关人员不会故意或无意泄漏客户的有价值信息；
- 4) 应主动识别服务相关人员在服务过程中可能造成客户信息的不完整或不可用

，制定服务规范和相应措施规避此风险；

- 5) 应做到“适当勤奋”，识别出服务相关人员接触到的客户信息系统所面临的物理、人员、管理、设置等方面的安全风险，告知客户并提供相应建议；
- 6) 进行适度的安全检查，以确保安全风险和安全事件的暴漏和处理；
- 7) 进行全面的信息安全教育，做到信息安全，人人有责；
- 8) 主动地进行信息安全方面的评审和改进，确保安全体系的有效。

8. 信息安全事件处理流程

8.1. 信息安全事件的定义

指影响范围广、已经造成公司或客户秘密资料泄漏、对业务连续性造成或可能造成一定影响的事件。

8.2. 信息安全事件的发现和报告

运维工程师发现信息安全事件后，应立即报告给行运维部经理。

事件发现人应尽可能将事件描述清晰，报告内容应包括但不限于事件的性质、发生的时间、现象、影响范围、严重程度。

运维部经理在收到运维工程师的信息安全事件报告后，应再次确认并填写《信息安全事件处理表》，必要时上报运维部经理。

8.3. 信息安全事件的处理和解决

信息安全事件的处置过程由运维部经理或者运维部经理统一指挥并决定处置策略，并按照实际情况确定是否需要启动相应应急预案。处理过程中应全程进行跟踪记录事件/事故的处理过程，填写《信息安全事件处理表》。在事件处理过程中须视事态变化。

8.4. 信息安全事件的关闭

事件处理部门应组织相关人员对发生的信息安全事件进行深入分析、总结、吸取教训、查找风险隐患、提出改善建议，制定预防措施，形成《信息安全事件处理表》，预防此类事件再次发生。

9. 安全措施和安全规范

公司信息化设备管理：

- 1) 严禁将公司配发给员工用于办公的计算机转借给非公司员工使用，严禁利用公司信息化设备资源为第三方从事兼职工作。
- 2) 公司所有硬件服务器统一放置在机房内，由公司网络管理员承担管理职责，由专人负责服务器杀毒、升级、备份。
- 3) 非公司技术人员对我单位的设备、系统等进行维修、维护时，必须由公司相关技术人员现场全程监督。计算机设备送外维修，必须经过部门负责人批准。
- 4) 严格遵守计算机设备使用及安全操作规程和正确的使用方法。任何人不允许私自对信息化设备进行维修及操作，不得擅自拆卸、更换或破坏信息化设备及其部件。
- 5) 计算机的使用部门和个人要保持清洁、安全、良好的计算机设备工作环境，禁止在计算机应用环境中放置易燃易爆、强腐蚀、强磁性等有害计算机设备安全的物品。
- 6) 原则上公司所有终端电脑、服务器都必须设定开机登录密码和屏幕保护密码，对于交换机、防火墙、路由器等网络设备也必须设置管理密码。
- 7) 公司所有终端电脑、服务器都必须安装正版杀毒软件，公司网络管理员必须对服务器进行定期杀毒、病毒库升级、补丁修复。

10. 公司网络管理员安全管理策略

公司所有服务器，由公司网络管理员实施统一管理。网络管理员管理权限必须经过部门经理授权取得。网络管理员负责各服务器的操作系统环境生成、维护，负责常规用户的运维和管理。网络管理员调离岗位，上级管理者或负责人应及时注销其管理密码并生成新的管理密码。

11. 密码与权限管理策略

- 1) 密码设置应具有安全性、保密性，不能使用简单的代码和标记。
- 2) 密码是保护系统和数据安全的控制代码，也是保护用户自身权益的控制代码。密码设置不应是名字、生日、重复、顺序、规律数字等容易猜测的数字和字符串；密码如发现或怀疑密码遗失或泄露应立即修改。
- 3) 服务器、防火墙、路由器、交换机等重要设备的管理密码由公司网络管理员（不参与系统开发和维护的人员）设置和管理，并由密码设置人员将密码妥善保存。

- 4) 有关密码授权工作人员调离岗位，公司网络管理员应对密码立即修改或用户删除。

12. 公司信息安全管理策略

- 1) 公司每一位员工都有保守公司信息安全防止泄密的责任，任何人不得向任何单位或个人泄露公司技术和商业机密，如因学术交流或论文发表涉及公司技术或商业机密，应提前向公司汇报，并在获取批准同意后，方能对外发布。
。
- 2) 定期对公司重要信息包括软件代码进行备份，管理人员实施备份操作时，必须有两人在场，备份完成后，立即交由研发中心封存保管。
- 3) 存放备份数据的介质包括电脑、U盘、移动硬盘、光盘和纸质，所有备份介质必须明确标识备份内容和事件，并实行异地存放。
- 4) 数据恢复前，必须对原环境的数据进行备份，防止有用数据的丢失。数据恢复过程中，如果出现问题时由工程中心进行现场技术支持。
- 5) 数据清理前必须对数据进行备份，在确认备份正确后方可进行清理操作。历次清理前的备份数据要进行定期保存或者永久保存，并确保可以随时使用。数据清理的实施应避开业务高峰期避免对联系业务运行造成影响。
- 6) 非本公司技术人员对本公司的设备、系统等进行维修、维护时，必须由本公司相关技术人员现场全程监督。计算机设备送外维修，须经设备管理机构负责人批准。送修前，需将设备存储介质内的应用程序和数据等信息备份后删除，并进行登记。对修复的设备，设备维修人员对应设备进行验收、病毒检测和登记。
- 7) 应对报废设备中存有的流程、数据资料进行备份后清除，并妥善处理废弃无用的资料和介质，防止泄密。
- 8) 公司网路管理员负责计算机病毒的防范工作，经常进行计算机病毒检查，发现病毒及时清除。

13. 运维项目现场/客户的信息安全管理策略

- 1) 公司每一位员工都有保守客户信息安全，防止泄密的责任，任何人不得向任何单位或个人泄密客户信息。
- 2) 各项目经理应主动向客户提出信息安全管理服务，若客户不愿意做，项目经理应向客户阐明利弊，提出合理的信息安全管理服务建议。

- 3) 如果为客户提供的数据备份服务，应定期对服务范围内的重要信息进行备份，管理人员实施备份操作时，必须有两人在场，备份完成后，立即交由客户制定的备份管理人员进行保管。
- 4) 存放备份数据的介质包括电脑、U盘、移动硬盘、光盘和纸质等，涉密单位介质使用参照客户保密要求。
- 5) 数据恢复前，必须对原环境的数据进行备份，防止有用数据的丢失。数据恢复后，必须进行验证、确认，确保数据恢复的完整性和可用性。
- 6) 数据清理前必须对数据进行备份，在确认备份正确后可进行清理操作，历次清理前的备份数据要定期保存或者永久保存，并确保可以随时使用。数据清理的实施应避开业务高峰期避免对客户业务运行造成影响。
- 7) 同意送修的设备，送修前，需将设备存储介质内的应用程序和数据等涉及经营管理的信息备份后删除，并进行登记。对修复的设备，应进行病毒检测。
- 8) 综合管理部应对报废设备中存有的流程、数据资料进行备份后清除，并妥善处理废弃无用的资料和介质，防止泄密。
- 9) 严禁利用客户的信息化设备资源为第三方提供服务。
- 10) 非客户授权人员对服务范围内的设备、系统等进行维修、维护时，必须由相关技术人员现场全程监督。计算机设备送外维修，必须经过客户相关负责人批准。
- 11) 禁止在计算机应用环境中放置易燃易爆、强腐蚀、强磁性等有害计算机设备安全的物品。
- 12) 客户的密码管理需由客户指定专人进行管理，项目经理应建议客户定期修改并妥善保管。
- 13) 涉及系统管理员的服务项目，系统管理员权限由客户授权。

14. 流程指标

为保证信息安全管理流程的有效性，定义以下关键绩效指标（KPI）和其他相关评价标准用以衡量信息安全管理流程的有效性和效率：不能出现安全事故

重大信息安全事件数量 = 我方人员造成重大信息安全事件的次数

15. 流程持续改进

- 流程负责人定期开展信息安全管理流程回顾工作，召开回顾会议，与流程相关人员讨论流程实施及流程改进措施；

- 流程负责人根据会议讨论的内容，进一步制定流程改进点，同时将对流程的改进写进服务改进计划；
- 执行改进计划：流程负责人组织协调相关人员，执行流程改进计划。